

Secure Staging Deployment & Automation Blueprint

Three tasks. Ten fail-closed gates. Twelve binary validation rules.
Mistake-proofing by construction, not by vigilance.

Vivek R

vivek 987pm@gmail.com | +91 8590609366

Candidate, Junior Cloud & DevOps Engineer (GCP / Django / React)

Two Incidents, One Root Cause

INCIDENT 01

Credentials in raw code

Unencrypted application programming interface keys committed directly into source; discoverable by anyone with repository access.

INCIDENT 02

Schema mismatch broke analytics

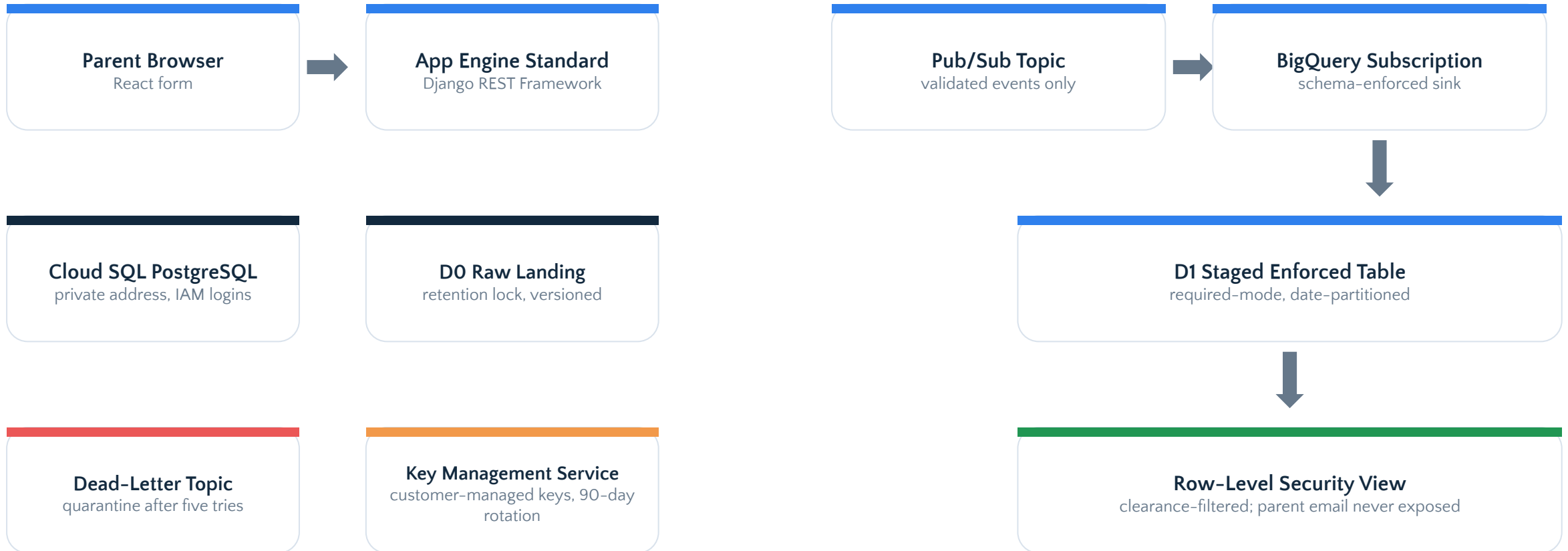
An upstream payload change diverged from the warehouse contract; downstream queries failed silently until reports were already wrong.

Root cause: quality depended on human memory.

The response demonstrated in this submission:

Poka-Yoke – automated gates that make the wrong path impossible, so the standard holds even on the worst day.

One Region, One Validated Path Into Analytics



Terraform Design

8

FOCUSED MODULES

100%

INPUTS VALIDATED AT PLAN TIME

fmt + validate

GREEN IN CI, PROVIDER SCHEMAS

project_services required APIs	kms_encryption rotating keys + agent grants
storage_raw_landing D0 bucket hardening	bigquery_staged D1 dataset, RLS view
pubsub_pipeline events, DLQ, schema sink	cloud_sql_staging private PostgreSQL, VPC
app_engine_staging app shell + runtime identity	iam_bindings every grant, conditional

Bad input dies at plan time; keys and the App Engine region refuse destruction.

Controls an Auditor Can Verify in Minutes

Encryption

Customer-managed keys rotate every 90 days across Storage, BigQuery, Pub/Sub.

Immutability

Retention lock + versioning + soft delete defeat deletion and ransomware paths.

Database

No public address. Passwordless IAM logins: revocation equals disabling one identity.

Quarantine, not silence

Failed deliveries land encrypted in a dead-letter topic with triage subscription.

No secrets in source

Full-history Git leaks + Trivy secret scanning; failures print redacted output.

Evidence by default

Every acceptance persists its complete per-rule decision record.

Least Privilege, Written Down Once

Identity	May do	Hard boundary
Runtime (App Engine)	Publish events; create objects; reach SQL; write logs/metrics	Objects only under incoming/ (IAM condition)
Data loader	Read archives; load into staged dataset; replay curated events	Reads only under raw/ (IAM condition)
Analytics viewer	Run jobs; SELECT through secure view	View-only grant; parent email excluded from projection
Pub/Sub agent	Deliver into enforced table; forward failures	Dataset-scoped editor; dead-letter publisher

Four project-wide roles total – each already the narrowest Google defines.
Everything else binds at resource level or under object-prefix conditions. All grants live in one reviewable file.

Ten Gates Between Commit and Promotion



ANY RED RESULT ANYWHERE

Downstream jobs never start. Attestation never prints. Evidence is quarantined. Branch protection blocks the merge.

ONLY ON ALL-GREEN

Gate 10 prints the promotion attestation naming the exact commit – the sole artifact eligible for staging deployment.

Standing drill: every run re-plants the training secret outside its allowlist

and asserts the detector still fires – detector health is proven continuously, never assumed.

Fail-Closed Behavior You Can Reproduce Today

PASS

Valid documentation change

All ten gates green; attestation names the commit eligible for promotion.

FAIL

Malformed module committed

Formatting gate exits non-zero; downstream never starts; merge blocked.

FAIL

Planted secret committed

Detector exits 1 over full history; output redacted; report quarantined.

DRILL

Detector health, every run

Planted fixture outside the allowlist must trip Gitleaks – or the build fails.

Exact Limits, Zero Judgment

PRESENCE AND TYPES

- Unknown fields rejected outright
- Coercion forbidden: an integer is not a name
- Stable machine-readable codes per surface

BOUNDARIES

- Names: 2 to 120 characters, letter grammar
- Phone: international pattern, 8 to 15 digits
- Age: exactly 2 accepted, 1 day short rejected; 18 in, 19 out

CONSENTS

- Literal boolean true only
- False, null, "true", and 1 all reject
- Consent is never defaulted or inferred

One constants module feeds serializer, model, BigQuery schema, and both spreadsheets.

A limit changes in exactly one place – or the build tells us.

ERR_AGE_OUTSIDE_WINDOW_CHILD_DATE_OF_BIRTH

every rejection carries its code

Twelve Rules, Two Outcomes, One Verdict

R01 YES/NO
parent name valid

R02 YES/NO
email structurally valid

R03 YES/NO
phone international

R04 YES/NO
child name valid

R05 YES/NO
birth date is ISO

R06 YES/NO
age within 2-18

R07 YES/NO
category in closed set

R08 YES/NO
summary bounds or absent

R09 YES/NO
parental consent true

R10 YES/NO
processing consent true

R11 YES/NO
envelope: no unknowns

R12 YES/NO
exact JSON types



// ATTESTATION VERDICT

```
{"all_rules_passed": true,  
"rules": [{"rule_id": "R01", "outcome": "YES"},  
... {"rule_id": "R12", "outcome": "YES"}]}
```

Persisted with every accepted submission — auditability against the exact rules in force.

Framework-Free Evaluator

Identical verdicts at request time, in tests,
and over archived payloads replayed from D0. Decision and validation
matrices ship as verified spreadsheets.

Deterministic Proof, Not Hope

86

DETERMINISTIC TESTS, ALL GREEN

3

LAYERS: LIBRARY, SERIALIZER, ENDPOINT

both sides

OF EVERY BOUNDARY PROBED

byte-equa

RECORDS ON REPEATED INPUT

Layer	What is pinned down
Library	Each of twelve rules: valid, invalid, missing, mistyped; injectable evaluation date
Serializer	Per-field codes; envelope strictness; coercion attempts; trim and case normalization
Endpoint	201 accept persists + publishes; 400 reject persists nothing; identical repeats stay identical

What This Blueprint Guarantees

- ✓ All three tasks delivered; every requirement traced to file-level evidence
- ✓ Assumptions documented where the document was silent – never invented silently
- ✓ Fail-closed end to end: bad code cannot deploy; bad data cannot enter analytics
- ✓ Auditability by construction: decisions persist beside the data they admitted

NEXT HARDENING STEPS

Cloud Armor edge policy

Actions pinned by commit hash

Native row-access policies on provider support